

OWASP Top 10

Web Application Security Risk Prioritization: 2017 • 2021 • 2025

The OWASP Top 10 is the foundational awareness document for web application security, published by the Open Web Application Security Project (OWASP) Foundation. It represents broad consensus on the most critical risks facing web applications, updated approximately every four years based on contributed vulnerability data and community survey. The table below tracks how each category has moved across the three editions released in the past decade, with the most recent 2025 edition reflecting the shift toward supply-chain risk, configuration complexity, and modern cloud-native architectures.

#	Code	Category	2017	2021	2025	Trend
1	A01	Broken Access Control <i>incl. SSRF rolled in (2025)</i>	#5	#1	#1	↑↑
2	A02	Security Misconfiguration <i>incl. XXE absorbed (2021)</i>	#6	#5	#2	↑↑↑
3	A03	Software Supply Chain Failures <i>expanded from Vulnerable & Outdated Components</i>	#9	#6	■ #3 ★	↑↑↑
4	A04	Cryptographic Failures <i>was Sensitive Data Exposure</i>	#3	#2	#4	↓
5	A05	Injection <i>incl. XSS (2021+); SQL, NoSQL, OS, LDAP</i>	#1	#3	#5	↓↓
6	A06	Insecure Design <i>new in 2021; focus on design-level flaws</i>	—	■ #4 ★	#6	↓
7	A07	Authentication Failures <i>was Identification & Auth Failures (2021)</i>	#2	#7	#7	↓↓
8	A08	Software or Data Integrity Failures <i>was Insecure Deserialization</i>	#8	#8	#8	→
9	A09	Security Logging & Alerting Failures <i>was Logging & Monitoring Failures</i>	#10	#9	#9	↑
10	A10	Mishandling of Exceptional Conditions <i>new in 2025; improper error/exception handling</i>	—	—	■ #10 ★	New
Removed / merged categories						
		SSRF (Server-Side Request Forgery) <i>merged into A01 Broken Access Control (2025)</i>	—	#10	merged	■ A01
		XML External Entities (XXE) <i>merged into A05 Security Misconfiguration (2021)</i>	#4	merged	—	■ A05

N ★ New or significantly expanded category

merged Removed / consolidated in that cycle

↑ Rising ↓ Declining → Stable

OWASP Top 10:2025

Practical Examples & Real-World Scenarios

The following table provides a practical description and a concrete real-world attack scenario for each of the ten categories in the OWASP Top 10:2025. These examples are intended to ground the abstract category names in the kinds of vulnerabilities and incidents security teams encounter in practice.

ID	Vulnerability Name	Practical Description	Real-World Example
A01	Broken Access Control	Users acting outside their intended permissions. This now includes SSRF.	Changing a user ID parameter in a URL (e.g., /account?id=123 to id=124) to view another person's private billing details.
A02	Security Misconfiguration	Missing security hardening, relying on default configurations, or improper cloud permissions.	Leaving a default admin password (admin/admin) active on a production server, or keeping an AWS S3 bucket open to the public.
A03	Software Supply Chain Failures	Vulnerabilities arising from compromised third-party code, dependencies, or build environments.	A popular open-source package you rely on is compromised by an attacker who injects a backdoor, infecting your app during the build process.
A04	Cryptographic Failures	Failures to adequately protect sensitive data in transit or at rest.	Transmitting credit card numbers over plain HTTP or storing user passwords using an outdated, easily cracked hashing algorithm like MD5.
A05	Injection	Untrusted user data is sent to an interpreter as part of a command or query, altering its execution.	A user inputs ' OR 1=1 -- into a login field, tricking the SQL database into granting them access without a valid password.
A06	Insecure Design	Flaws related to missing or ineffective control design, highlighting a lack of upfront threat modeling.	Implementing a password recovery workflow that relies on easily guessable security questions (like "What is your pet's name?") rather than multi-factor authentication.
A07	Authentication Failures	Weaknesses in verifying a user's identity or managing user sessions securely.	Lacking rate-limiting on a login page, allowing an attacker to run automated brute-force attacks until they successfully guess a password.
A08	Software or Data Integrity Failures	Making assumptions about the integrity of software updates, CI/CD pipelines, or data without verifying them.	An application accepts and processes an over-the-air update without verifying its digital signature, leading to remote malicious code execution.
A09	Security Logging & Alerting Failures	Failing to log critical security events or generate alerts, making breach detection nearly impossible.	Not logging repeated failed login attempts, giving an attacker unlimited, unnoticed time to quietly compromise a user's account over several days.
A10	Mishandling of Exceptional Conditions	Improper error handling leading to denial of service, state corruption, or information disclosure.	An app encounters an unexpected error and crashes, dumping a full stack trace to the browser that reveals internal database structures to an attacker.

OWASP Resources & References

[1] OWASP Top 10 project page (all editions)

<https://owasp.org/www-project-top-ten/>

Compiled March 30, 2026 • Data sourced from OWASP Foundation official publications.